

CLOUD-PHISH GUARD

Application Security Overview

Adaptive Identity Intelligence & Cloud Breach Prevention

1. Purpose & Scope

This document outlines the data protection policies and architectural design applicable to the Cloud-Phish Guard application and explains how those policies are technically enforced within the system.

Cloud-Phish Guard is an adaptive AI-driven authentication middleware designed to detect and neutralize phishing attacks before any cloud data is exposed. Because the system processes user credentials, behavioural data, and network metadata, robust data protection is central to its design, not an afterthought.

2. Data Classification

Cloud-Phish Guard handles three categories of data:

Data Category	Examples	Sensitivity	Retention
Identity & Credential Data	Username, hashed passwords, OTPs, biometric tokens	HIGH	Session lifetime only; never persisted
Behavioural & Network Metadata	Login location, device fingerprint, IP, traffic patterns	MEDIUM	30 days for anomaly detection models
Incident / Audit Logs	Blocked attempts, account-freeze events, threat classifications	MEDIUM	90 days; encrypted at rest

3. Applicable Data Protection Policies

3.1 Principle of Data Minimisation

Cloud-Phish Guard collects only the data required to assess authentication risk. Plain-text credentials are never stored; they are used transiently during the authentication check and immediately discarded. Behavioural metadata is anonymised before being fed into the AI model.

Policy: Collect the minimum data necessary.
Application in Cloud-Phish Guard: Credentials are hashed (bcrypt/Argon2) at the point of entry. Only risk-scoring signals (not raw credentials) are forwarded to the AI pipeline.

3.2 Data Encryption

All data in transit is encrypted using TLS 1.3. All data at rest (logs, model training sets) is encrypted using AES-256. AWS KMS (Key Management Service) manages encryption keys, with automatic rotation every 90 days.

Data State	Encryption Standard	Key Management
In Transit	TLS 1.3 (HTTPS enforced)	AWS Certificate Manager
At Rest — Logs	AES-256	AWS KMS (auto-rotated 90 days)
At Rest — Model Data	AES-256	AWS KMS
Biometric Tokens	SHA-3 one-way hash	Never reconstructible

3.3 Access Control & Least Privilege

Cloud-Phish Guard enforces the principle of least privilege across all layers. Backend services run in isolated containers (ECS/EKS) with IAM roles granting only the permissions each service requires. No service has write access to the incident log store; only append is permitted.

- AWS IAM roles scoped per microservice (no shared admin credentials)
 - Cognito manages user identity pools with MFA enforced for admin accounts
 - API Gateway authorises every inbound request before it reaches backend logic
 - Audit logs are append-only; no service can overwrite or delete log entries
-

3.4 Purpose Limitation

Data collected by Cloud-Phish Guard is used solely for authentication risk assessment and threat detection. Behavioural and network metadata is never shared with third parties, sold, or used for advertising. Model retraining uses anonymised, aggregated incident data only.

3.5 Breach Notification & Incident Response

If a security incident is detected, Cloud-Phish Guard's Neutralisation Engine responds automatically (account freeze, cloud isolation), and the incident is logged for manual review. In the event of a confirmed data breach affecting users, the response timeline is:

1. Automated detection and containment within seconds of anomaly detection
2. Internal security review within 24 hours
3. Affected user notification within 72 hours (aligned with GDPR and POPIA timelines)
4. Regulatory reporting where required by South African POPIA legislation

3.6 POPIA Alignment (South Africa)

As a South African product targeting the domestic market, where phishing accounts for 52 % of cyberthreats, Cloud-Phish Guard is designed to comply with the Protection of Personal Information Act (POPIA):

- Lawful processing: data is processed only to provide the security service the user has requested
- Information quality: behavioural data is regularly cleansed; stale records are purged after the retention window
- Security safeguards: encryption, access controls, and automated threat response meet or exceed POPIA Section 19 requirements
- Data subject rights: users can request deletion of their behavioural profile at any time via the account management interface

4. Architecture Design — How Security Layers Connect

The diagram below shows the complete request flow through Cloud-Phish Guard, from user action to cloud resource access (or neutralisation). Each row is a layer in the security stack; the system operates as smart middleware between the user and the cloud backend.

LAYER		
USER / CLIENT	Browser or mobile app sends a login / API request	Request origin
↓ INTERNET	TLS-encrypted traffic (HTTPS)	
API GATEWAY (Cloud-Phish Guard Layer)	AWS API Gateway intercepts every request before it reaches any backend service	AWS API Gateway / Apigee
↓ MIDDLEWARE	Custom filter pipeline begins	
PATH ANALYSIS	Monitors connection routes, detects unusual network behaviour, eavesdropping, and MITM risks in real time	Cloudflare WAF / AWS WAF / ModSecurity
↓		
LURE DETECTION (AI/NLP)	NLP engine scans text, URLs & site patterns for phishing signals, urgency/authority markers, fake pages	Node.js / Python FastAPI / Go — custom filter
↓		
ADAPTIVE GATE	Risk-based authentication engine: low-risk → pass medium-risk → step-up MFA high-risk → block + freeze	Behaviour & device context scoring
↓ RISK = LOW	Credentials & tokens verified	
CUSTOM AUTHENTICATOR	OTP + Biometrics + Device verification (multi-factor, layered)	Flexible > OTP + Biometrics + Device ID
↓ AUTHENTICATED	Access granted to cloud resources	
CLOUD BACKEND (AWS)	EC2 / Lambda, ECS/EKS, SageMaker AI/ML, Cognito, Shield, WAF, Kinesis streaming	Kinesis data streaming for real-time logging
↓ HIGH-RISK EVENT	Automatic neutralisation triggered	
NEUTRALISATION ENGINE	Account frozen → Cloud isolation protocols → Incident logged → Future detection improved	S3 / CloudWatch incident logs → SageMaker retraining

Total Shielding Guarantee:
"The hacker never sees a single byte of cloud data."

This is achieved because every request is evaluated by Path Analysis → Lure Detection → Adaptive Gate before any cloud resource is touched. High-risk requests are neutralised at the gateway layer.

5. Security Features Mapped to Data Protection

Cloud-Phish Guard Feature	Data Protection Mechanism	Policy Addressed
Path Analysis	Monitors connections for MITM / eavesdropping; encrypts in-flight data signals	Encryption, Integrity
Lure Detection (AI/NLP)	Scans content at the network edge before credentials are entered	Data Minimisation, Purpose Limitation
Adaptive Gate	Risk-based MFA blocks access before any cloud data is read	Access Control, Breach Prevention
Custom Authenticator	OTP + Biometrics + Device ID, no single factor is sufficient	Access Control, Least Privilege
Neutralisation Engine	Account freeze + cloud isolation + append-only incident log	Breach Notification, Audit Trail
AWS WAF / Shield	Blocks volumetric attacks and SQL-injection attempts at the perimeter	Integrity, Availability
AWS KMS Encryption	Manages and rotates all encryption keys automatically	Encryption at Rest
AWS Cognito	Manages user identity pools and enforces MFA for privileged accounts	Access Control

6. Vulnerabilities Mitigated

The following three primary vulnerabilities are directly addressed by the data protection architecture:

6.1 Broken Authentication

Poor session management and token handling allow attackers to hijack active cloud sessions. Cloud-Phish Guard mitigates this by:

- Using short-lived JWT tokens with refresh-token rotation
- Detecting unusual session behaviour (new device, geographic anomaly) and triggering step-up authentication
- Immediately revoking tokens when high-risk activity is detected by the Adaptive Gate

6.2 Security Misconfiguration

Default permissions and open storage buckets provide an easy entry point once the perimeter is breached. Cloud-Phish Guard mitigates this by:

- Enforcing least-privilege IAM roles for every microservice
- Running automated misconfiguration scans (AWS Config rules) on all S3 buckets and security groups
- Blocking access at the API Gateway before any misconfigured resource can be reached

6.3 Phishing-Based Credential Theft

Social engineering bypasses hardware-based security. Cloud-Phish Guard mitigates this by:

- The Lure Detection engine uses NLP to identify urgency/authority language patterns that traditional filters miss
- Fake website detection cross-references URL patterns, SSL certificate age, and domain reputation
- Even if credentials are stolen, the Adaptive Gate's behavioural analysis detects anomalous logins and blocks access

Investing in Cloud-Phish Guard's layered data protection is not optional; it is the only cost-effective way to prevent losses that dwarf the build cost.

7. Summary

Cloud-Phish Guard applies data protection by design across every layer of its architecture:

- Data is minimised - only risk signals, never raw credentials, flow through the AI pipeline
 - Data is encrypted - TLS 1.3 in transit, AES-256 at rest, KMS-managed keys
 - Access is controlled - least-privilege IAM, Cognito MFA, append-only audit logs
 - Breaches are contained automatically - freeze, isolate, log, notify within 72 hours
 - The system is POPIA-aligned - lawful processing, user rights, and security safeguards are baked in
-

Core Design Philosophy:

Every security control in Cloud-Phish Guard exists to protect one thing: the user's data. The Adaptive Gate, Lure Detection, and Neutralisation Engine together ensure that a phishing attacker never reaches the cloud data layer at all.
